

CHOWDHURY HASAN MAHMUD

Senior Cybersecurity & AI Security Executive | Acting CISO | Agentic AI & GenAI Governance

CISM • CISA • PMP • CCSP • ITIL 4 • GSEC • (In Progress) IAPP AIGP, ISO/IEC 42001 LI

NYC Metro | (347) 836-2171 | hasanpmpo@gmail.com | [linkedin.com/in/hassan-c-755696234](https://www.linkedin.com/in/hassan-c-755696234) | github.com/hasanpmpo |

Remote / Hybrid / Federal / NYC Civil Service

PROFESSIONAL SUMMARY

Cybersecurity and IT program executive with 18+ years leading enterprise information security, GRC, and mission-critical technology for NYC public safety, public health, healthcare, and global enterprises. Acting CISO for NYC's largest public safety agency with a proven record of delivering zero-trust, AI-aided security operations and SOC 2 Type II, FedRAMP, FISMA, NIST 800-53/800-171, ISO 27001, HIPAA, CJIS, and NYDFS Part 500 compliance under regulatory scrutiny.

Early adopter of Agentic AI and Generative AI in cybersecurity — designing Retrieval-Augmented Generation (RAG) pipelines, LangChain / LangGraph multi-agent workflows, Model Context Protocol (MCP) server integrations, LLM guardrails, hallucination detection, and prompt-injection defenses aligned to NIST AI RMF 1.0, NIST AI 600-1 (GenAI Profile), ISO/IEC 42001, EU AI Act, OMB M-24-10, and Executive Order 14110. Trusted advisor to DCAS, OTI, NYC Cyber Command, and federal/state oversight partners on AI TRISM, Responsible AI, and secure adoption of GenAI across regulated civil-service environments.

AI, GENAI & AGENTIC SECURITY HIGHLIGHTS

- **Agentic AI & Multi-Agent Orchestration:** Designed production-grade agentic workflows using LangChain, LangGraph, AutoGen, CrewAI, and Semantic Kernel for SOC triage, phishing analysis, and vulnerability-prioritization copilots — with human-in-the-loop approval gates, tool-use policies, and audit-ready action logs.
- **RAG & Grounding:** Architected Retrieval-Augmented Generation (RAG) pipelines over vector stores (Azure AI Search, pgvector, FAISS, Pinecone) with chunking, embedding (OpenAI, Cohere, Azure OpenAI), re-ranking, and RAGAS evaluation — grounding security copilots in FDNY policy, NIST control libraries, NYC Cybersecurity Directives, and CJIS Security Policy to suppress hallucinations.
- **Model Context Protocol (MCP):** Stood up and hardened MCP servers exposing SIEM, EDR, ticketing, and vulnerability data to GenAI assistants with least-privilege scopes, signed tool manifests, token-bound access, and full request/response telemetry — enabling safe analyst-augmentation without data exfiltration risk.
- **LLM Guardrails & Safety:** Implemented layered guardrails using NVIDIA NeMo Guardrails, Guardrails AI, Microsoft PyRIT, Azure AI Content Safety, and Purview DLP-for-AI — covering prompt-injection, jailbreak, data-leakage, toxicity, PII/PHI redaction, and output validation for OWASP LLM Top 10 and MITRE ATLAS threats.
- **Hallucination & Factuality Management:** Built hallucination-detection and groundedness-scoring controls (retrieval-grounded evaluation, citation enforcement, self-consistency, LLM-as-a-Judge, Ragas faithfulness/answer-relevancy, Azure AI Evaluations) with governance SLOs reported to the CIO and Inspector General functions.
- **AI Governance & Assurance:** Authored enterprise AI policy, model inventory / AI Bill of Materials (AI-BOM), model cards, DPIAs, and AI red-team playbooks aligned to NIST AI RMF, NIST AI 600-1, ISO/IEC 42001, EU AI Act, and White House EO 14110 — including procurement guardrails for vendor LLMs (Accenture, Cognizant, GCOM, Microsoft, AWS, Google).
- **LLMOps & Observability:** Deployed LLMOps stack (Azure AI Foundry, Azure OpenAI, AWS Bedrock, Langfuse, Arize AI, MLflow, Weights & Biases) for prompt versioning, drift detection, cost/latency telemetry, and continuous red-team testing of production agents.

CORE COMPETENCIES

- Cybersecurity Program Leadership, Acting CISO & Deputy CISO Operations
- AI / GenAI / Agentic AI Security: RAG, MCP, LangChain, LangGraph, Guardrails, Hallucination Mitigation, Prompt Injection Defense, AI Red-Teaming
- AI Governance & Assurance: NIST AI RMF 1.0, NIST AI 600-1 (GenAI), ISO/IEC 42001, ISO/IEC 23894, EU AI Act, OMB M-24-10, EO 14110, OWASP LLM Top 10, MITRE ATLAS, AI TRISM
- Risk Management & GRC: NIST 800-53 / 800-171 / CSF 2.0 / RMF, FISMA, FedRAMP, StateRAMP, CMMC 2.0, ISO 27001/27017/27018, SOC 2 Type II, HIPAA, PCI-DSS, NYDFS Part 500, CJIS
- Zero-Trust Architecture (EO 14028, OMB M-22-09), Cloud Security (Azure, AWS, GCP), SIEM / SOAR, EDR / XDR, IAM, PAM, DLP, CASB

- Incident Response, Threat Intelligence, Purple Teaming, Business Continuity / Disaster Recovery
- Enterprise Portfolio & Program Management (PMP, Agile, Scrum, SAFe 6, DevSecOps, PMO build-out, OCM)
- Vendor Risk Management, Third-Party Assurance, Contract Negotiation, Public Procurement (NYC PPB, MOCS, PASSPort)
- Executive & Board Reporting, KRI/KPI Dashboards, Security Metrics, Regulatory Testimony

PROFESSIONAL CERTIFICATIONS

CISM (ISACA) • CISA (ISACA) • CCSP (ISC²) • PMP (PMI) • ITIL 4 Foundation • GIAC GSEC • CCNA Security • (In Progress) IAPP AIGP (AI Governance Professional), ISO/IEC 42001 Lead Implementer, Microsoft AI-900 / AI-102, AWS AI Practitioner

PROFESSIONAL EXPERIENCE

Fire Department of the City of New York (FDNY) — Brooklyn, NY

2016 – Present

Acting CISO / Senior Cybersecurity Posture Manager & ISSO • NYC Civil Service — Computer Specialist (Software) Title 13632, Level 2 (Permanent)

- Serve as Acting CISO for NYC's largest public safety agency (17,000+ employees, 2M+ annual emergency calls), owning enterprise security strategy, AI governance, incident response, and business continuity for 911/CAD, EMSCAD, EMS, and mission-critical platforms.
- Direct a multi-million-dollar cybersecurity portfolio covering cloud migration, zero-trust architecture, SIEM/SOAR, EDR/XDR, PAM, DLP, and AI-assisted threat detection across hybrid Azure / AWS / on-premises environments.
- Led FDNY to become the first major metropolitan fire department to achieve SOC 2 Type II certification; delivered FedRAMP authorization for EMS cloud systems and maintained a 98% audit pass rate across NIST 800-53, ISO 27001, HIPAA, CJIS, and NYDFS Part 500.
- Stood up the agency's first AI-Aided SOC: LLM-powered alert-triage copilots with RAG grounding in FDNY runbooks and NIST control libraries, LangGraph multi-agent phishing analysis, and MCP-based tool access to SIEM/EDR — cutting Tier-1 analyst toil ~40% and MTTC on phishing by ~55%.
- Designed LLM guardrail layer (NeMo Guardrails + Azure AI Content Safety + Purview DLP) preventing prompt-injection, PII/PHI leakage, and policy-violating outputs; instituted hallucination-scoring and citation-enforcement controls reported in monthly CIO/IG dashboards.
- Authored FDNY AI Acceptable-Use Policy, AI Bill of Materials (AI-BOM), and model-risk management framework aligned to NIST AI RMF 1.0, NIST AI 600-1, ISO/IEC 42001, NYC AI Action Plan, and White House EO 14110 — adopted as reference by peer NYC agencies.
- Deployed CrowdStrike Falcon EDR on 800+ endpoints, implemented DMARC with Global Cyber Alliance (90% reduction in email spoofing), and drove 70% reduction in critical vulnerability exposure via Rapid7, Tenable, Qualys, and ARMIS.
- Led end-to-end incident lifecycle management for 40+ annual security events in coordination with NYC Cyber Command and FBI/CISA partners, with zero operational disruption to emergency services and 99.97% uptime for 911/CAD.
- Manage vendor and third-party risk for 50+ suppliers (Motorola, Accenture, CrowdStrike, Fortinet, Palo Alto, Forcepoint, GCOM); lead independent QA review of FireCAD, EMSCAD, and UCMS programs, flagging scope, cost, and conflict-of-interest risks to executive leadership and oversight bodies.
- Deliver board-level analytics and cyber posture reports to FDNY executive staff, NYC DCAS, OTI, DOI, Comptroller, and oversight committees — translating technical risk into plain-language fiscal and public-safety impact.

NYC Department of Health & Mental Hygiene (DOHMH) — Queens, NY

2012 – 2016

Technical Innovation & Cybersecurity Program Manager

- Managed enterprise cybersecurity and IT modernization programs for NYC DOHMH, securing 40+ healthcare applications serving 8.5M residents.
- Delivered HIPAA Security Rule, NYDFS Part 500, NIST CSF, and ISO 27001 compliance; implemented IAM, MFA, SIEM (Splunk), and vulnerability management across Azure and AWS.
- Led rapid Authority to Operate (ATO) and security authorization of 15 emergency-response platforms during COVID-19 on compressed timelines without compromising regulatory posture.
- Established DevSecOps pipeline practices, zero-trust baselines, and cross-agency GRC processes adopted by C-Suite and citywide leadership.

Earlier Experience

- **Medisys Health Network — IT Risk Analyst & Compliance Officer (2009–2012):** Led HIPAA, SOX, and PCI-DSS compliance for a 3,000-user healthcare network; reduced critical exposures by 60% through automated vulnerability management and remediation workflows.
- **G-Star RAW (Amsterdam, NL) — Risk & IT Governance Analyst / EDI & 3PL PM (2007–2009):** Led controls, vendor risk reviews, EDI integration, and supply-chain technology projects for EU payment and health systems.
- **King Saud Medical City (Riyadh, KSA) — Head of Technical & EHR Development (2008–2012, concurrent):** Directed hospital computerization, EMR, and IVR rollouts, migrating manual workflows to enterprise automation.

SIGNATURE ACHIEVEMENTS

- First major metropolitan fire department in the U.S. to achieve SOC 2 Type II.
- FedRAMP authorization delivered for mission-critical EMS cloud systems.
- Stood up NYC's first AI-Aided SOC with RAG + LangGraph + MCP, reducing analyst toil ~40%.
- Authored FDNY AI governance policy and AI-BOM adopted as reference by peer NYC agencies.
- 70% reduction in critical vulnerability exposure through risk-based remediation.
- 90% reduction in email spoofing after DMARC deployment with Global Cyber Alliance.
- 98% audit pass rate across NIST 800-53, ISO 27001, HIPAA, CJIS, NYDFS Part 500.
- 99.97% uptime maintained for 911/CAD during major cybersecurity upgrades.
- Secured 15 emergency-response platforms in compressed timelines during COVID-19.

TECHNICAL PROFICIENCIES

AI & Agentic Security: RAG (Retrieval-Augmented Generation), LangChain, LangGraph, AutoGen, CrewAI, Semantic Kernel, Model Context Protocol (MCP), NVIDIA NeMo Guardrails, Guardrails AI, Microsoft PyRIT, Azure AI Content Safety, Purview DLP-for-AI, Hallucination detection (RAGAS, LLM-as-a-Judge, Azure AI Evaluations), Prompt-injection & jailbreak defense, AI red-teaming, Microsoft Security Copilot, Google SecLM, AWS Bedrock Guardrails, OpenAI / Anthropic / Gemini APIs, Embeddings (OpenAI, Cohere), Vector DBs (pgvector, FAISS, Pinecone, Azure AI Search), LLMops (Langfuse, Arize, MLflow, Weights & Biases)

AI Governance: NIST AI RMF 1.0, NIST AI 600-1 (GenAI Profile), ISO/IEC 42001, ISO/IEC 23894, EU AI Act, OMB M-24-10, White House EO 14110, OWASP LLM Top 10, MITRE ATLAS, AI TRISM, Model Cards, AI-BOM, DPIAs, Responsible AI

Security Frameworks: NIST 800-53, NIST 800-171, NIST CSF 2.0, NIST RMF, FISMA, FedRAMP, StateRAMP, CMMC 2.0, ISO 27001/27017/27018, SOC 2 Type II, CJIS, HIPAA Security Rule, PCI-DSS, NYDFS Part 500, COBIT 2019, CIS Controls v8

Detection & Response: CrowdStrike Falcon EDR/XDR, Splunk ES, IBM QRadar, LogRhythm, Microsoft Sentinel, Azure Defender, ExtraHop, Carbon Black, SOAR (Cortex XSOAR, Splunk SOAR)

Cloud & Network: Microsoft Azure (Defender, Sentinel, Purview, AI Foundry, Azure OpenAI), AWS (GuardDuty, Security Hub, IAM, Bedrock), GCP Security Command Center, CSPM / CNAPP (Wiz, Prisma Cloud), Palo Alto, Fortinet FortiGate/FortiNAC, Cisco Firepower, Zero-Trust Architecture

IAM & PAM: Okta, Microsoft Entra ID, CyberArk, SailPoint IdentityIQ, SAML/OAuth/OIDC, MFA, PKI, Privileged Access Management

Vulnerability & Offensive: Rapid7 InsightVM, Tenable Nessus, Qualys, ARMIS, Burp Suite Pro, Metasploit, OWASP ZAP, AI red-team tooling (PyRIT, Garak)

DevSecOps & Automation: Jenkins, GitHub Actions, GitLab CI/CD, Docker, Kubernetes, Terraform, IaC scanning (Checkov, tfsec), Python, PowerShell, Bash

GRC & PMO: ServiceNow GRC, RSA Archer, MetricStream, Jira, Confluence, MS Project, Oracle PPM, HP ALM, PASSPort (NYC MOCS)

FEATURED PUBLIC PROJECTS (GITHUB)

- **Ayesha_Cybersecurity** — github.com/hasanpmp/ro/Ayesha_Cybersecurity — Reference architecture for an AI-aided SOC: LangGraph agentic triage, RAG over NIST 800-53, MCP server for SIEM tool use, and NeMo Guardrails for prompt-injection defense.
- **AI-BOM-Template** — AI Bill of Materials template aligned to NIST AI 600-1 and EU AI Act Annex IV for public-sector agencies.
- **NYC-GenAI-Governance-Playbook** — Opinionated playbook for NYC civil-service adoption of GenAI: procurement guardrails, model cards, DPIAs, and red-team checklists.

EDUCATION

- **B.Sc., Business Information Systems** — University of East London, United Kingdom
- **Diploma, Information Technology & Engineering** — University of Queensland, Australia

PUBLIC SECTOR ELIGIBILITY

- NYC Civil Service — Computer Specialist (Software) Title 13632, Level 2, Permanent (12+ years).
- Eligible for Public Trust / Secret clearance sponsorship; familiar with SF-85P, SF-86, and CJIS fingerprint-based background standards.
- U.S. work authorization: permanent. Open to NYC, NY State, federal (OPM USAJOBS), and contractor roles requiring cleared personnel.